11 Authorization for APIs

This chapter covers

- Why API authorization is difficult in a microservices environment
- Three enforcement patterns for internal APIs: gateway, service mesh, and per-service proxies
- How OAuth allows delegated access without sharing passwords
- OAuth's Authorization Code Grant and the Client Credentials Grant
- How access tokens are integrated with Cedar for fine-grained authorization

APIs serve as the connective tissue for modern digital systems. Every mobile app, SaaS product, and microservice relies on APIs to transfer data and initiate operations across organizational and technical boundaries. That widespread use makes API security a critical concern. If APIs are left too open, they become vulnerable to misuse or attack. Conversely, if they are overly restricted, they hinder the integrations and workflows that make modern software ecosystems possible. Authorization for APIs has to balance two requirements:

- **Internal enforcement**: ensuring only authorized services and employees can access sensitive endpoints within an organization's own systems
- **External delegation**: providing customers with secure and managed methods for third-party apps to access APIs on their behalf

Both are essential, but they require different methods. Internal service-to-service interactions need runtime policy evaluation to enforce corporate rules consistently across many APIs. Customer-driven delegation, on the other hand, relies on protocols that allow people to grant limited access without sharing their passwords.